MBA982 — Project Module Report

Temporal Knowledge Graph + X-FAMHA-GNN Cybersecurity Risk Assessment:
A Scoped Reproduction with Grounded LLM Assistant

Field	Detail
Course	MBA982 — Project Module
Report type	Project Review / Module Report
Base paper	Bag, Sarkar, and Bose (2025), *Enhancing cybersecurity risk assessment using temporal knowledge graph-based explainable decision support system*, *Decision Support Systems*, 198, 114526
Domain	Cybersecurity policy risk assessment (temporal knowledge graphs)
Case-study scale	18 companies (15 breached, 3 comparatively clean)
Code repository	https://github.com/balajibrk/mba982-famha-cyber-risk
Implementation	Python 3.12 (PyTorch CUDA, Torch Geometric, NLTK, SHAP, Ollama / Llama 3.1 8B, Streamlit)
Hardware	NVIDIA RTX 2000 Ada Generation Laptop GPU (8 GB VRAM)

1. Executive Summary

This project reproduces the core technical contribution of Bag, Sarkar, and Bose (2025) — hereafter Bag et al. (2025) — and adds a novel **grounded LLM security-assistant layer** that the original paper does not include. The paper builds **temporal cybersecurity knowledge graphs** from policy and attack text, then classifies four-level policy risk with an **X-FAMHA-GNN** (Factor-Analysis-based Multi-Head Attention Graph Neural Network).

Main finding. On a scoped 18-company case study with leave-one-out cross-validation, X-FAMHA-GNN achieves **accuracy 0.611** and **macro-F1 0.461**, beating GATConv (**0.444 / 0.329**) and a majority-class baseline (**0.444 / 0.154**). Across five random seeds, Mann–Whitney U tests (one-sided) give **$p = 0.0040$** (F1 vs GAT) and **$p = 0.0037$** (F1 vs majority), both below $\alpha = 0.05$. FAMHA attention uses **1,638** parameters versus **9,216** for an equivalent vanilla multi-head design (~5.6× reduction), consistent with the paper's Theorem 3.1.

LLM design claim. The assistant is deliberately *not* a chatbot that invents risk numbers. Remediation **impact** is obtained by **re-running the trained GNN** on an edited knowledge graph (counterfactual re-score). Local Ollama (Llama 3.1 8B) only narrates that precomputed evidence. Example: Uber high/critical risk mass **1.000** $\rightarrow$ **0.041 (–95.9%)**; Capital One **1.000** $\rightarrow$ **0.924 (–7.6%)**.

All code, validation scripts, result tables, and documentation are available in the public repository linked above.

2. Base Paper: Bag, Sarkar, and Bose (2025)

2.1 Bibliographic details

> Bag, Sujoy, Sarkar, Sobhan, and Bose, Indranil. 2025. “Enhancing cybersecurity risk assessment using temporal knowledge graph-based explainable decision support system.” *Decision Support Systems* 198: 114526. https://doi.org/10.1016/j.dss.2025.114526

2.2 Abstract of the base paper (summary)

Bag et al. (2025) propose an explainable decision-support system for cybersecurity risk assessment. Corporate policy documents and breach / attack articles are processed into a **temporal knowledge graph**. A novel attention mechanism — **FAMHA (Factor-Analysis-based Multi-Head Attention)** — determines the number of attention heads from the eigenvalue structure of feature covariance (Kaiser / factor-retention logic), partitions feature dimensions via principal-axis factor analysis, and applies scaled neighbour attention with composition back to the original feature order. The resulting **X-FAMHA-GNN** predicts multi-class vulnerability / policy risk and is interpreted with SHAP values and attention heatmaps. The paper reports large-scale evaluation (on the order of **190 train / 154 test** companies) against multiple baselines and benchmark datasets.

2.3 What this project reproduces vs. scopes down

Dimension	Bag et al. (2025)	This project (MBA982)
Companies	~190 train / 154 test	**18** proof-of-concept case study
Labels	idtheftcenter / upguard-style severity	Documented 4-factor heuristic (`docs/labeling_methodology.md`)
Text corpus	Scraped policy + breach pages	**Curated** fact-grounded policy + attack text (PoC-flagged)
Coref / OIE / NER	Neural coref, Stanford OpenIE, CyNER	Rule-based coref, NLTK SVO OIE, cyber gazetteer NER
FAMHA (Algorithm 1)	Original	**Faithful reimplementation** + unit tests
Baselines	10 SOTA models	**GATConv** + majority-class
Benchmarks	4 datasets	Case study only (UPFD stretch descoped)
Interpretability	SHAP + attention	Same
Remediation impact	Static residual-risk style tables	**Live GNN counterfactual re-score**
LLM assistant	Not present	**Local Ollama grounded narrative**
Demo UI	Not emphasised	Streamlit app

---

3. Research Question and Objectives

3.1 Research question

> Can a faithful implementation of FAMHA / X-FAMHA-GNN on temporal cybersecurity knowledge graphs recover the paper's qualitative claims (predictive advantage over GAT-style attention; parameter efficiency; interpretable entity attributions) on a scoped case study, and can an LLM assistant report remediation impact that is *proven* by model re-scoring rather than generated as free text?

3.2 Project objectives

1. Reconstruct the Bag et al. pipeline: corpus → clean → temporal KG → embeddings → FAMHA GNN → baselines → interpretability.
2. Implement FAMHA Algorithm 1 to the mathematics (head count, PAFA partition, √(d/2) attention, composition, Θ_FAMHA < Θ_normal).
3. Evaluate with leave-one-out CV, GATConv and majority baselines, and Mann–Whitney U across seeds.
4. Add a grounded LLM layer: counterfactual GNN re-score → evidence-only narrative (Ollama with template fallback).
5. Deliver a public, phase-validated codebase and this module report for faculty review.

---

4. Data

4.1 Overall sample design

Item	Specification
Company set	18 firms (see §4.2)
Risk classes	4 — `low_risk`, `medium_risk`, `high_risk`, `critical_risk`
Text types per company	Cybersecurity **policy** narrative + **attack / breach** narrative
Graph unit	One temporal knowledge graph per company (GraphML)
Train / test protocol	**Leave-one-out CV** over 18 graphs (honest for small N)
Embedding model	Sentence-BERT `all-MiniLM-L6-v2` (384-d)

4.2 Company list

Group	Count	Companies
Breached	15	Uber, Capital One, Equifax, Target, Marriott, JPMorgan Chase, Citigroup, Wells Fargo, SolarWinds, Colonial Pipeline, Okta, LastPass, Progress MOVEit, Twitter, Yahoo
Comparatively clean	3	Apple, Cloudflare, Stripe

Metadata (sector, breach year, approximate records exposed, disclosure delay, recurrence, root-cause text, policy areas, attack entities) is stored in `src/config.py`.

4.3 Text corpus (curated seed)

Path	Content
`data/raw/policies/{slug}.txt`	Policy-control narrative for the firm
`data/raw/attacks/{slug}.txt`	Breach / threat narrative grounded in **documented public facts** (or "no major breach" for clean firms)

Every raw file begins with a `# PROOF-OF-CONCEPT` provenance header. Text is authored to be SVO-friendly for open information extraction. This is **not** scraped ground truth; it is a transparent PoC corpus for a short academic timeline.

4.4 Labeling methodology

Labels are **not** taken from proprietary severity APIs used in the paper. They follow an explicit heuristic in `docs/labeling_methodology.md`:

```
risk_score = factor_scope + factor_delay + factor_recurrence + factor_rootsev # 0..10
```

Factor	Basis	Range
Scope	log-bucket of records exposed	0–4
Disclosure delay	days to public disclosure	0–2
Recurrence	distinct major breaches	0–2
Root-cause severity	systemic / concealment / critical-infrastructure judgment	0–2

Composite score	Class
0–1	`low_risk` (0)
2–4	`medium_risk` (1)
5–7	`high_risk` (2)
8–10	`critical_risk` (3)

Observed distribution: low 3 / medium 5 / high 8 / critical 2.

4.5 Knowledge-graph statistics

After Phase 2 construction: typically **~26–43 nodes** and **~22–33 edges** per company; **526** raw triples across the corpus; **117** unique verbs clustered into the paper's **8 canonical relations** (`implements`, `aligns-with`, `violates`, `mitigates`, `causes`, `impacts`, `reports`, `regulates`). See `docs/data_manifest.csv` and `docs/kg_stats.csv`.

5. Methodology (Step by Step)

Step 1 — Corpus build and cleaning (`src/preprocess/`)

1. Generate curated policy + attack files and `data/labels/labels.json`.
2. Clean with NLTK: sentence tokenize → strip URLs/noise → SymSpell → **WordNetLemmatizer** (matches the lemmatizer cited by the paper).
3. Write cleaned sentence files and `docs/data_manifest.csv`.

> **Environment note:** spaCy was blocked by Windows Smart App Control (unsigned DLLs). NLTK is pure Python and remains faithful to the paper's lemmatization choice.

Step 2 — Temporal knowledge graph (`src/kg/`)

1. **Coreference:** resolve aliases / "the company" → canonical firm name.
2. **OIE:** NLTK POS + NP-chunk SVO triples.
3. **NER typing:** gazetteer → ORG / POLICY / ATTACK / ASSET / ENTITY.
4. **Canonicalization:** MiniLM embeddings + agglomerative clustering (cosine, τ = 0.30) → map to 8 relations.
5. **Temporal labels:** breach year / publish proxy on nodes and edges.
6. Export `data/processed/kg/{slug}.graphml`.

Step 3 — Node features (`src/model/features.py`)

Each node feature is:

[
\mathbf{x}*v \;=\; \bigl[\; \text{type one-hot (5)},\;\; \text{MiniLM}(\text{label})*{(384)},\;\; \text{normalised year (1)} \;\bigr]
]

so (d_{\text{in}} = 390). A learnable linear layer maps to (d_{\text{model}} = 32).

Step 4 — FAMHA + X-FAMHA-GNN (`src/model/famha.py`, `xfamha_gnn.py`)

Faithful Algorithm 1:

1. **Head count** from feature-covariance eigenvalues (Kaiser: # eigenvalues above the mean).
2. **PAFA partition** of (d) columns into (h) groups with (\sum \mathrm{len}_i = d).
3. Per-head attention scaled by (\sqrt{d/2}), neighbour-masked softmax, sigmoid; compose columns back.
4. Stack **3** FAMHA blocks with ELU + residual FFN → global mean pool → 4-way softmax.

Unit tests verify head-count response to eigenvalue spread and (\Theta_{\text{FAMHA}} < \Theta_{\text{normal}}).

Step 5 — Training and baselines (`src/train/`, `src/baselines/`)

1. Leave-one-out CV (150 epochs, class-weighted cross-entropy, Adam).

2. GATConv baseline under the same protocol.
3. Majority-class baseline.
4. Five-seed Mann–Whitney U on accuracy and macro-F1.
5. Save final model on all companies for interpretability / assistant stages.

Step 6 — Interpretability (`src/interpret/`)

1. SHAP KernelExplainer over node-presence masks → top-entity charts.
2. FAMHA attention heatmaps (policy entities × attack entities).

Step 7 — Grounded LLM assistant (`src/assistant/`)

1. **Counterfactual:** neutralize attack-side weakness entities; inject MFA / least-privilege control node; **re-run trained GNN** → `risk_before`, `risk_after`, (\Delta).
2. **Narrative:** Ollama `llama3.1:8b` with evidence-only system rules; JSON `{one_line_verdict, why, fix, impact}`; ungrounded-number check; template fallback if Ollama is down.
3. Streamlit demo: `app/demo_app.py`.

---

6. Results

6.1 Leave-one-out classification (primary run)

Model	Accuracy	Macro-F1
X-FAMHA-GNN	**0.611**	**0.461**
GATConv	0.444	0.329
Majority-class	0.444	0.154

Training loss on fold 1 decreases cleanly (≈1.388 → 0.026). G-mean is low because only **two** critical-class firms exist under LOO — disclosed as a small-sample limitation, not hidden.

6.2 Robustness across five seeds + Mann–Whitney U

Model	Accuracy (mean ± std)	Macro-F1 (mean)
X-FAMHA-GNN	0.600 ± 0.042	0.495
GATConv	0.456 ± 0.074	0.340

Contrast	Metric	(p)-value (X-FAMHA greater)
vs GATConv	Accuracy	0.0096
vs GATConv	Macro-F1	**0.0040**

vs Majority	Accuracy	0.0035
vs Majority	Macro-F1	**0.0037**

All below $\alpha = 0.05$. See `docs/results.csv`.

6.3 FAMHA parameter efficiency

Quantity	Value
Θ_FAMHA (trained stack)	1,638
Θ_vanilla MHA equivalent	9,216
Reduction	~5.6×

6.4 Interpretability sanity

Company	Top SHAP / attention themes	Public narrative alignment
Uber	credentials, AWS S3 / related assets	2016 credential / cloud datastore breach
Capital One	cloud configurations, internal metadata	SSRF / cloud IAM / metadata exposure

6.5 Counterfactual re-score + LLM narrative

Company	Risk before	Risk after	Δ	Class shift
Uber	1.000	0.041	–**95.9%**	critical → low
Capital One	1.000	0.924	–**7.6%**	stays high (smaller move)

Narratives were produced by **Ollama `llama3.1:8b`** and validated for JSON schema + no ungrounded numbers (`tests/validate_phase6.py`).

6.6 Mapping results back to Bag et al. claims

Paper claim	Evidence in this MBA982 project	Verdict
FAMHA is implementable and parameter-efficient	Unit tests + 1,638 vs 9,216 params	**Supported**
X-FAMHA-GNN beats graph-attention style baseline	Acc/F1 > GAT; MWU $p < 0.05$	**Supported** (scoped N)
Explanations surface meaningful entities	Uber / Capital One SHAP match public facts	**Supported**
Large-scale severity labels / 10 baselines	Heuristic labels; 1 GAT + majority	**Scoped down** (disclosed)

Static residual-risk table	Replaced by live GNN counterfactual	**Extended** (novel)

7. Discussion

7.1 What transferred cleanly from the paper

The methodological skeleton — temporal KG construction, eight canonical relations, FAMHA head determination + factor partition, ELU GNN stack, SHAP / attention interpretability — is portable. Even at N = 18, X-FAMHA-GNN outperforms GATConv with statistical support across seeds, and FAMHA's parameter inequality holds.

7.2 What is novel: LLM as narrator, GNN as reasoner

Typical "AI + LLM" demo	This project
LLM invents "risk reduced by ~40%"	GNN recalculates risk; LLM quotes that number
Chart caption generation	Evidence package: SHAP + attention + edited-graph Δ
Cloud LLM as black-box scorer	Local LLM as **narrator**; GNN as **reasoner**

7.3 Real-time operational uses of the LLM layer

1. Analyst triage when a company is selected in Streamlit.
2. Executive one-pager from `exec_summary`.
3. Engineering ticket JSON (severity, remediation, expected impact).
4. Remediation prioritisation by comparing counterfactual Δ across firms.
5. Template fallback when Ollama is down — **impact numbers still model-true**.

These are on-demand analyses over case-study graphs, not live SIEM monitoring.

8. Limitations

1. **Universe size.** N = 18 vs. hundreds in the paper → illustrative, not equally powered.
2. **Label construct.** Heuristic labels approximate severity; transparent but not identical to idtheftcenter / upguard.
3. **Corpus construct.** Curated SVO text is fact-grounded but authored; KG structure partly reflects authoring choices.
4. **Class imbalance.** Only two critical firms → LOO and G-mean suffer on that class.
5. **NLP stack.** Rule-based coref / NLTK OIE / gazetteer NER replace neural CyNER / OpenIE (Smart App Control + timeline).
6. **Baselines.** One GATConv + majority vs. ten SOTA models in the paper.
7. **Counterfactual semantics.** Graph edit (mask attack entities + inject MFA) is a structured what-if, not a full SOC playbook.

8. **LLM residual risk.** Prompting and numeric checks reduce hallucination; impact remains trustworthy because it is model-sourced.

These are scope constraints of an MBA module reproduction, not failures of the original paper.

---

9. Reproducibility and Code Access

Item	Location
Public GitHub repository	https://github.com/balajibrk/mba982-famha-cyber-risk
Configuration / companies / labels	`src/config.py`, `docs/labeling_methodology.md`
Preprocess	`src/preprocess/build_corpus.py`, `clean.py`
Knowledge graph	`src/kg/`
Model	`src/model/famha.py`, `xfamha_gnn.py`, `features.py`
Training / significance	`src/train/train_case_study.py`, `significance.py`
Baseline	`src/baselines/run_baselines.py`
Interpretability	`src/interpret/`
LLM assistant	`src/assistant/`
Demo	`app/demo_app.py`
Phase validation	`tests/validate_phase1.py` … `validate_phase6.py`
Results tables	`docs/results.csv`, `docs/kg_stats.csv`, `docs/data_manifest.csv`
Dependencies	`requirements.txt`

Recommended run order

```
python -m src.preprocess.build_corpus python -m src.preprocess.clean python -m
src.kg.build_graph python -m src.model.features python -m src.train.train_case_study python -m
src.baselines.run_baselines python -m src.train.significance python -m
src.interpret.shap_explain python -m src.assistant.pipeline uber capital_one streamlit run
app/demo_app.py
```

Environment setup (Python 3.12 via `uv`, CUDA torch, Ollama model pull) is documented in `README.md`.

---

10. Conclusion

This MBA982 project module reproduces the temporal knowledge-graph + X-FAMHA-GNN cybersecurity risk framework of Bag, Sarkar, and Bose (2025) on a transparent 18-company case study, and extends it with a grounded LLM assistant. We find that:

1. **X-FAMHA-GNN outperforms GATConv and majority baselines** under leave-one-out CV (acc **0.611**, F1 **0.461**), with Mann–Whitney F1 **p** ≈ **0.004**.
2. **FAMHA is parameter-efficient** (~5.6× fewer attention parameters than vanilla multi-head) and passes Algorithm 1 unit tests.
3. **SHAP / attention explanations** align with known public breach mechanisms for sample firms.
4. **Remediation impact is model-proven**: the LLM reports GNN counterfactual deltas (e.g. Uber –**95.9%**), not invented percentages.
5. The full pipeline and this report are openly available at **https://github.com/balajibrk/mba982-famha-cyber-risk** for faculty review.

Overall, the project shows that Bag et al.'s methodological core is implementable on a scoped corpus, while clarifying which conclusions survive small-N constraints — and demonstrating how an LLM can be attached without becoming the source of the risk number.

References

1. Bag, S., Sarkar, S., & Bose, I. (2025). Enhancing cybersecurity risk assessment using temporal knowledge graph-based explainable decision support system. *Decision Support Systems*, *198*, 114526. https://doi.org/10.1016/j.dss.2025.114526
2. Veli■kovi■, P., Cucurull, G., Casanova, A., Romero, A., Liò, P., & Bengio, Y. (2018). Graph Attention Networks. *ICLR*.
3. Lundberg, S. M., & Lee, S.-I. (2017). A unified approach to interpreting model predictions. *NeurIPS* (SHAP).
4. Reimers, N., & Gurevych, I. (2019). Sentence-BERT: Sentence embeddings using Siamese BERT-networks. *EMNLP*.
5. Meta AI / Ollama. Llama 3.1 8B — https://ollama.com/library/llama3.1

```
@article{bag2025cyber, title = {Enhancing cybersecurity risk assessment using temporal
knowledge graph-based explainable decision support system}, author = {Bag, Sujoy and Sarkar,
Sobhan and Bose, Indranil}, journal = {Decision Support Systems}, volume = {198}, pages =
{114526}, year = {2025}, doi = {10.1016/j.dss.2025.114526} }
```

Appendix A — Repository structure (for review)

```
mba982-famha-cyber-risk/ ■■■ README.md ■■■ requirements.txt ■■■ app/demo_app.py ■■■
data/raw/{policies,attacks}/ ■■■ docs/ ■ ■■■ MBA982_Project_Module_Report.md # this report ■
■■■ MBA982_Project_Module_Report.pdf ■ ■■■ SUMMARY.md ■ ■■■ labeling_methodology.md ■ ■■■
results.csv ■ ■■■ data_manifest.csv ■ ■■■ kg_stats.csv ■■■ src/ ■ ■■■ config.py ■ ■■■
preprocess/ ■ ■■■ kg/ ■ ■■■ model/ # famha.py, xfamha_gnn.py, features.py ■ ■■■ train/ ■
■■■ baselines/ ■ ■■■ interpret/ ■ ■■■ assistant/ # counterfactual + narrative + pipeline
■■■ stubs/numba/ # Smart App Control workaround for SHAP ■■■ tests/validate_phase*.py
```

Appendix B — Data source and period checklist

Dataset / artefact	Source	Notes

Policy text (18 firms)	Curated PoC corpus in-repo	Grounded in realistic control language; PoC header
Attack / breach text (18 firms)	Curated PoC corpus in-repo	Grounded in documented public breach facts
Risk labels	Heuristic in `src/config.py`	See `docs/labeling_methodology.md`
Temporal stamps	Breach year / publish proxy	From company metadata + text years
Sentence embeddings	Hugging Face `all-MiniLM-L6-v2`	Used in canonicalization + node features
LLM narratives	Ollama `llama3.1:8b` (local)	Evidence-only; template fallback
Evaluation protocol	Leave-one-out over 18 graphs	5 seeds for significance

Appendix C — Resources (links)

Resource	Location
GitHub repository	https://github.com/balajibrk/mba982-famha-cyber-risk
This report (Markdown)	https://github.com/balajibrk/mba982-famha-cyber-risk/blob/main/docs/ME
This report (PDF)	https://github.com/balajibrk/mba982-famha-cyber-risk/blob/main/docs/ME
Project summary	https://github.com/balajibrk/mba982-famha-cyber-risk/blob/main/docs/SU
Labeling methodology	https://github.com/balajibrk/mba982-famha-cyber-risk/blob/main/docs/lab
README / setup	https://github.com/balajibrk/mba982-famha-cyber-risk/blob/main/READM
Source paper (DOI)	https://doi.org/10.1016/j.dss.2025.114526
PyTorch Geometric	https://pytorch-geometric.readthedocs.io/
SHAP	https://shap.readthedocs.io/
Sentence-Transformers	https://www.sbert.net/
Ollama	https://ollama.com/
Streamlit	https://streamlit.io/

End of MBA982 Project Module Report